12.1 Policy Information Points (PIPs)

In the abstract architecture of authorization introduced in figure 12.1, the Policy Information Point (PIP) appeared as a neat box feeding the PDP. That diagram captured the idea that policies rely on external data, but it concealed just how complex the real picture is. As shown in the figure, what looks like a single component in the abstract model is, in practice, a web of heterogeneous sources that must be integrated, secured, and kept fresh.

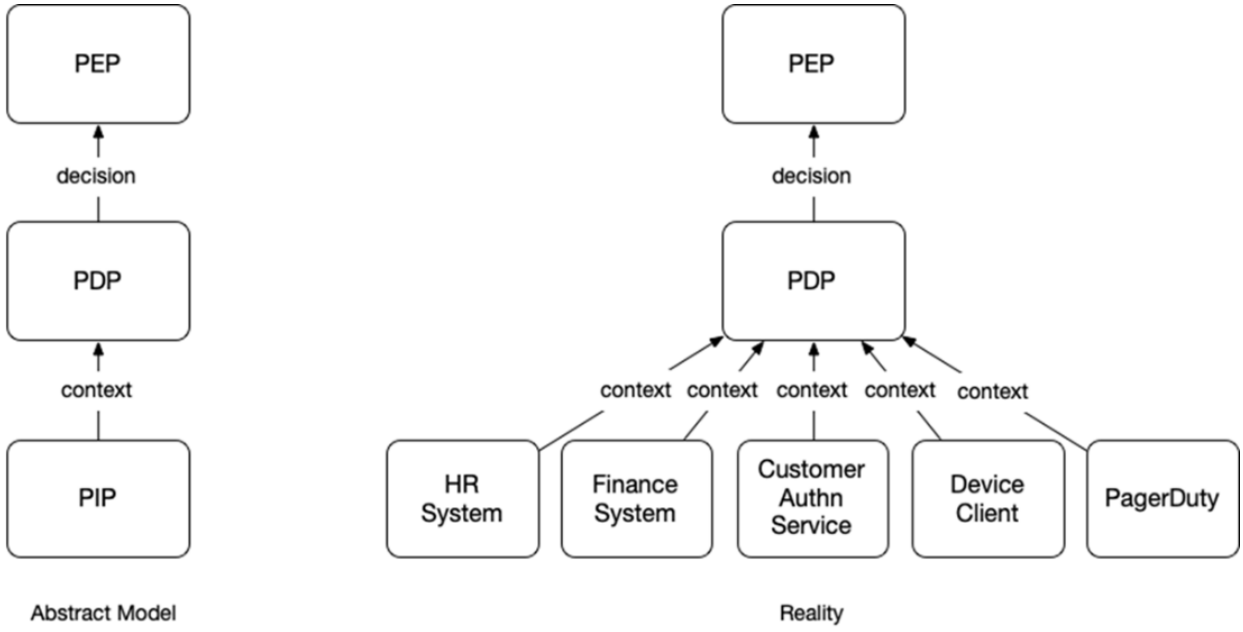


Figure 12.1 Policy Information Points: abstract vs. reality. Left: the abstract authorization architecture shows a single Policy Information Point (PIP) feeding data to the Policy Decision Point (PDP). Right: in practice, the PIP represents many sources—HR, Finance, authentication systems, device posture clients, external systems, and so on—all connected through APIs, tokens, and caches to deliver the trust signals that policies need.

Some signals come from internal systems: HR provides employment status, Finance supplies spending authority, IT contributes device inventories, and directories list group memberships. Others come from external providers, such as identity verification services, fraud detection engines, or SaaS partners that share risk scores. Still others are generated on the device itself, like a posture client that attests to whether the laptop is encrypted or patched.

The way these sources are handled depends heavily on the use case. Returning to the three-dimensional choice space introduced earlier, PIPs are